

Great. One clarification before we continue: **the previous response already started Category 2 (SAP Security Fundamentals)**. We'll continue it in the depth expected for a **Senior SAP Security/GRC Architect** interview.

From this point onward, I'll write it as a **professional handbook**, not as short interview notes.

CATEGORY 2 – SAP SECURITY FUNDAMENTALS (PART 2)

Chapter 2 – SAP Role Design & Authorization Concepts

Q11. What is Role-Based Access Control (RBAC)?

Interviewer's Objective

The interviewer wants to understand whether you know how to design enterprise roles—not just create them in PFCG.

Executive Answer

Role-Based Access Control (RBAC) is a security model where access is assigned to business roles instead of directly assigning authorizations to individual users.

Each role represents a specific job function within the organization, ensuring users receive only the access required to perform their responsibilities.

Rather than managing thousands of individual authorizations, organizations manage roles that are aligned with business processes.

RBAC Flow

```
graph TD; A[Business Process] --> B[Business Function]; B --> C[Job Position / Persona]; C --> D[Business Role]; D --> E[Technical Role];
```

Business Process

↓

Business Function

↓

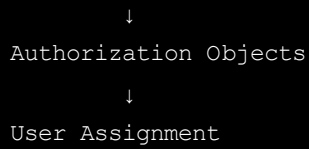
Job Position / Persona

↓

Business Role

↓

Technical Role



Example

Business Position	Business Role
Accounts Payable Clerk	AP Processor
Purchasing Manager	Procurement Manager
Production Planner	PP Planner
Warehouse Supervisor	Warehouse Lead
Finance Manager	Finance Manager

Benefits of RBAC

- Standardized access
- Easier audits
- Reduced SoD violations
- Simplified user provisioning
- Improved compliance
- Scalable across global organizations

Best Practice

Never design roles around people.

Always design roles around business responsibilities.

Q12. What are the different types of Roles in SAP?

Executive Answer

SAP supports several role types depending on business requirements.

Single Role

Contains

- Menu
- Authorization Objects
- Organizational Values

Example

Z_MM_BUYER



Composite Role

A collection of multiple single roles.

Used to simplify user administration.

Example

Finance Manager



↓

FI Display

FI Posting

Cost Center

Asset Accounting

Composite roles do not contain authorizations themselves; they group existing single roles.

Master Role

Contains

- Transactions
- Authorization Objects
- Menu

No organizational restrictions.

Derived Role

Derived from a Master Role.

Contains

Different

- Company Code
- Plant
- Sales Organization
- Purchasing Organization

Example

Master Role



↓

Z_MM_BUYER_MASTER

↓

Derived Roles

↓

Z_MM_BUYER_US

Z_MM_BUYER_UK

Z_MM_BUYER_INDIA

Z_MM_BUYER_SAUDI

Interview Question

Why use Derived Roles?

Executive Answer

Derived roles significantly reduce maintenance.

When new transactions or authorization objects are added to the master role, they automatically flow to all derived roles while preserving organization-specific values.

This ensures consistency and simplifies large-scale role administration.

Q13. Explain Organizational Levels.

Executive Answer

Organizational Levels restrict user access to specific business entities.

Examples include:

Module	Organizational Level
FI	Company Code
MM	Plant
MM	Purchasing Organization
SD	Sales Organization
SD	Distribution Channel
SD	Division
HR	Personnel Area
PP	Plant

Example

User A

Company Code

1000



User B

Company Code

2000



Both users may execute FB60.

However,

User A cannot post invoices for Company Code 2000.

Interview Tip

One of the most common authorization issues is not missing transactions—it is missing organizational values.

Always verify:

- Company Code
- Plant
- Purchasing Organization
- Sales Organization

before adding new authorizations.

Q14. Explain PFCG.

Executive Answer

PFCG (Profile Generator) is SAP's central tool for creating, maintaining, and assigning authorization roles.

A role in PFCG typically consists of:

- Menu
 - Authorizations
 - Organizational Levels
 - User Assignments
 - Generated Profile
-

Role Creation Process

Create Role



↓

Add Menu

↓

Maintain Authorization

↓

Maintain Organizational Levels

↓

Generate Authorization Profile

↓

User Assignment

↓

User Comparison

Common Interview Question

What happens when you press Generate?

Answer

SAP creates or regenerates the authorization profile associated with the role.

This profile contains the compiled authorization data that SAP uses during authorization checks.

Q15. Explain SU24.

One of the most frequently asked interview questions.

Executive Answer

SU24 stores SAP's authorization proposal data.

It defines:

- Authorization Objects
- Default Field Values
- Check Indicators

for each transaction.

During role maintenance in PFCG, SAP reads SU24 proposals to automatically populate relevant authorization objects.

Why is SU24 Important?

Without SU24



Role administrators would manually maintain every authorization object.

With SU24



SAP automatically proposes required authorizations.

Benefits

- Faster role maintenance
 - Standardized authorization design
 - Reduced manual effort
 - Better security consistency
-

Interview Follow-up

Do you modify SU24?

Answer

Yes, but only after careful review.

For custom transactions or Z programs, we validate the authorization logic and update SU24 proposals to ensure future role generation remains consistent.

Changes should follow governance processes because incorrect SU24 settings affect every future role built from that transaction.

Q16. What is User Comparison?

Executive Answer

After assigning a role to a user, SAP does not immediately update the user's authorization buffer.

User Comparison synchronizes the assigned roles and generated profiles with the user master record.

Without User Comparison,

Users may not receive newly assigned authorizations until the next synchronization.

Q17. Explain Authorization Trace.

Executive Answer

Authorization Trace helps determine why authorization checks succeed or fail.

SAP provides several tools.

Transaction	Purpose
SU53	Last failed authorization
STAUTHTRACE	Complete authorization trace
SU56	User authorization buffer
ST01	System trace (includes authorization checks)

Best Practice

Simple Issue

↓

SU53

Complex Fiori Issue

↓

STAUTHTRACE

Kernel-Level Investigation



ST01

Q18. Explain RFC Security.

This is a favorite question in architecture interviews.

Executive Answer

Remote Function Calls (RFCs) enable communication between SAP systems or between SAP and external applications.

RFC security focuses on ensuring these communications are secure and use only the minimum required privileges.

Best Practices

- ✓ Never use Dialog users for RFCs.
 - ✓ Use Communication or System users.
 - ✓ Restrict S_RFC authorization objects.
 - ✓ Secure RFC destinations (SM59).
 - ✓ Use SNC encryption where applicable.
 - ✓ Monitor trusted RFC connections regularly.
-

Interview Question

What risks arise from using SAP_ALL on an RFC user?

Answer

Granting SAP_ALL to an RFC user creates a high-risk attack vector. If the credentials are compromised, an attacker may gain unrestricted access to the target system, bypassing the principle of least privilege and significantly increasing compliance and security risks.

Q19. What is the Difference Between Authentication and Authorization?

Authentication

Verifies identity

Login process

Username & Password

SSO

IAS

Authorization

Determines permissions

Access control

Roles & Authorizations

PFCG

Authorization Objects

Simple Interview Answer

Authentication answers:

Who are you?

Authorization answers:

What are you allowed to do?

Q20. Explain the Principle of Least Privilege in a Real Project.

Executive Answer

In one S/4HANA transformation, business users requested broad access to speed up testing. Instead of granting SAP_ALL, we designed temporary project roles limited to the required transactions and organizational values.

Access requests were approved through SAP GRC ARM, reviewed for SoD conflicts using ARA, and removed after testing. This approach supported the project while maintaining compliance and avoiding unnecessary security exposure.

Advanced Interview Scenario

Interviewer

A Finance Director tells you, "My team is losing productivity because security is too restrictive. Give them SAP_ALL until go-live." How would you respond?

Executive Answer

I would explain that while I understand the business urgency, granting SAP_ALL would introduce significant audit and security risks and could invalidate Segregation of Duties controls.

Instead, I would propose:

1. Identify the exact business processes causing delays.
2. Create temporary, time-bound project roles with only the necessary access.
3. Route the request through SAP GRC ARM for approval.
4. Perform an SoD analysis using ARA.
5. If emergency access is required, use Firefighter IDs (EAM) with appropriate approvals and log reviews.
6. Remove temporary access immediately after go-live.

This approach balances operational needs with governance and ensures compliance without exposing the organization to unnecessary risk.

Senior Interview Insight

At Lead and Architect levels, interviewers assess not only your technical knowledge but also your judgment. They want to hear solutions that balance business enablement with security and compliance. Avoid answers that focus solely on SAP transactions; always explain the governance rationale behind your decisions.

End of Chapter 2

The next chapter in **Category 2** will cover **Advanced Authorization Concepts**, including:

- SAP_ALL vs. SAP_NEW
- Authorization Object design
- S_TABU_DIS vs. S_TABU_NAM
- Table authorization strategies
- Debug authorization
- Background job security
- Transport strategy for roles

- AGR_* tables (AGR_1251, AGR_USERS, AGR_DEFINE, etc.)
- Authorization troubleshooting case studies
- Common interview traps and expected answers

These topics are commonly used by senior interviewers to distinguish experienced SAP Security architects from administrators.